

Manual 15 - SOC 2 Controlled Implementation

Authority boundary: original implementation guidance. SOC 2 is an independent CPA attestation examination, not a certification.

Localized editions are controlled implementation translations and are not AICPA-authorized translations. The controlled English edition governs interpretation.

Manual 15 — Localization and Artifact Handoff

****State:**** controlled pre-publication preparation; not publication authorization

****Series order:**** 15

****Controlling English source blob:****
`92bd8eb8b51dbd1367e4968eaf3fad1b399af5d9`

****Controlling source:****
`English/source/CONTROLLED\_CHAPTERS\_01\_32.md`

Objective

Move Manual 15 from completed controlled English source into exact-source localization and publication-candidate preparation without changing the authoritative interpretation boundary or fabricating human semantic review.

Exact-source rule

All es-419 and pt-BR localized drafts must derive from the English source blob identified above. If the English source changes materially, localization parity and all downstream artifact hashes are invalidated and must be regenerated from the new exact source.

English remains the controlling interpretation. Localized editions are implementation translations and must not be described as AICPA-authorized or official translations.

Mandatory terminology boundaries

Preserve these distinctions in both localized editions:

- SOC 2 is an independent CPA attestation examination/reporting engagement, not a certification.
- Trust Services Criteria and Description Criteria are separate controlled concepts.
- Management owns the system description, assertion, controls, evidence and remediation; the independent practitioner owns examination procedures, professional judgment, opinion and report issuance.
- Type 1 and Type 2 readiness must remain distinct.
- Security, availability, processing integrity, confidentiality and privacy must remain separate categories where applicable.
- Complementary user-entity controls and subservice-organization responsibilities must not be collapsed into service-organization controls.
- Readiness assistance must never be represented as replacing independent CPA judgment.

es-419 controlled-draft requirements

Use professional Latin American Spanish suitable for GRC, audit, privacy, security and executive readers. Retain `SOC 2`, `Trust Services Criteria`, `Description Criteria`, `Type 1`, `Type 2` and other formal identifiers where translation could imply a different official term. Use consistent controlled equivalents for system description, assertion, service organization, subservice organization, complementary user-entity controls, evidence population, operating effectiveness, exception, remediation and reassessment.

The es-419 draft may be machine-assisted, but substantive semantic acceptance must be recorded separately if repository policy requires genuine human judgment.

pt-BR controlled-draft requirements

Use professional Brazilian Portuguese suitable for GRC, auditoria, privacidade, segurança and executive readers. Retain formal SOC identifiers where translating them could imply an official AICPA translation. Use consistent controlled equivalents for system description, assertion, service organization, subservice organization, complementary user-entity controls, evidence population, operating effectiveness, exception, remediation and reassessment.

The pt-BR draft may be machine-assisted, but substantive semantic acceptance must be recorded separately if repository policy requires genuine human judgment.

Parity QA

Before artifact generation, fail closed unless all three editions satisfy:

1. exactly 32 chapters in identical order;
2. equivalent chapter purpose and control/evidence intent;
3. no dropped management/practitioner independence boundary;
4. no new certification, endorsement or legal-compliance claim introduced by translation;
5. no omission of owners, frequencies/triggers, populations, evidence, exceptions/remediation or reassessment concepts where present in English;
6. no stale source lineage;
7. no protected AICPA criteria text reproduced beyond permissible use.

Publication-candidate generation

After trilingual source/parity QA, generate six candidate binaries from the exact controlled sources:

- EN DOCX and PDF;
- es-419 DOCX and PDF;
- pt-BR DOCX and PDF.

The generator must create reproducible metadata, language tags, headings, page numbering, controlled-use notice and source/provenance references. PDFs must undergo text-content preflight and rendered accessibility/visual review. DOCX/PDF files must not be resaved after SHA-256 binding.

Provenance and durability

For each candidate record:

- source path and source blob/commit;
- artifact path;
- SHA-256;
- generation workflow/run identifier;
- page/content QA result;
- accessibility/visual result;
- terminology/parity result;
- review evidence required by repository policy;
- predecessor publication state.

Validated binaries must then be durably staged to the repository without regeneration. Catalog and work-product release-registry changes occur only after all publication gates are satisfied.

Current blocker boundary

Manual 14 is published, so predecessor order is satisfied. Manual 15 is not publication-eligible until controlled es-419 and pt-BR editions, exact candidate artifacts, rendered/accessibility QA, checksum/provenance, durable artifact staging, and any explicitly required genuine-human substantive reviews are complete. Standing Final Human Release Approval remains separate and does not substitute for genuine-human review where repository policy explicitly requires it.

Manual 15 — SOC 2 Controlled Implementation

Controlled-use notice

This manual is an original implementation and readiness guide. It does not reproduce the AICPA Trust Services Criteria, Description Criteria, paid guidance, illustrative reports, or practitioner-only material. SOC 2 is an independent CPA attestation examination, not a certification. Management owns the system, controls, system description, assertions, evidence, and remediation; the independent practitioner owns examination judgments and the report.

Chapter 01 — Purpose, audience, and engagement context

Use this manual to build a repeatable SOC 2 readiness and control-evidence operating model. Define why the organization needs a SOC 2 report, intended users, services involved, expected timing, likely report type, and relevant trust-services categories. Name an executive sponsor, readiness lead, system-description owner, control owners, evidence providers, remediation owners, and legal/privacy/technology stakeholders. Maintain a decision log for scope, criteria, report type, subservice treatment, significant assumptions, and changes.

Evidence should include the business requirement, readiness charter, RACI, milestones, auditor-selection criteria, decision log, and documented boundary between readiness support and independent CPA judgment.

Chapter 02 — Service-organization boundary and system definition

Define the service organization and the system that delivers the in-scope services. Identify infrastructure, software, data, people, procedures, physical locations, cloud services, development and support processes, identities, monitoring services, and material third parties. Start from customer commitments and actual service delivery rather than selecting a convenient technical perimeter.

Maintain a scope statement, component inventory, architecture/data-flow diagrams, service catalog, ownership records, dependency map, and change-

triggered reassessment. Every exclusion should have a documented rationale and impact analysis.

Chapter 03 — Management responsibilities and assertion

Management is responsible for designing, implementing, operating, monitoring, and describing controls and for making the representations required for the engagement. Assign accountable executives and operational control owners, establish evidence responsibilities, and require management review of significant deficiencies, incidents, exceptions, and description changes.

Do not delegate management responsibility to a readiness consultant or the service auditor. Retain approval records, management representations, control-owner attestations, issue decisions, and evidence showing that management understands the system and control environment it describes.

Chapter 04 — System description and description criteria readiness

Build the system description from verifiable operating facts. Describe the services, system boundaries, infrastructure, software, people, procedures, data, significant commitments, significant events, applicable controls, subservice organizations, and complementary user-entity responsibilities. Keep marketing claims separate from assurance statements.

Use a controlled authoring process with an owner, contributors, version history, evidence links, review checkpoints, and change triggers. Reconcile the description against architecture, contracts, inventories, policies, incidents, and actual operating evidence before examination fieldwork.

Chapter 05 — Trust Services Criteria structure and controlled mapping

Treat the applicable Trust Services Criteria as assurance criteria, not as a prescribed technology checklist. Begin with commitments, system requirements, risks, and control objectives, then map implemented controls to applicable criterion identifiers using legally permissible references. Security is foundational; availability, processing integrity, confidentiality, and privacy are included when relevant to the engagement.

Maintain a criterion-to-risk-to-control matrix that records owner, control activity, frequency, population, evidence, test approach, exceptions, and

change triggers. Points of focus may inform implementation thinking but should not be represented as separate mandatory controls unless authoritative guidance requires that treatment.

Chapter 06 — Security/common-criteria implementation model

Build an integrated security control environment covering governance, risk assessment, communication, access, operations, monitoring, change, incident response, vendor dependencies, and corrective action. Controls should connect to actual risks and system commitments and should operate consistently throughout the relevant period.

For each security control, document purpose, owner, procedure, frequency or trigger, system/population boundary, evidence source, reviewer, exception path, and reassessment trigger. Avoid duplicate controls that produce conflicting evidence or unclear accountability.

Chapter 07 — Availability implementation model

Where availability is in scope, translate service commitments into capacity, resilience, backup, recovery, monitoring, incident, and continuity controls. Define measurable objectives and dependencies that support the organization's commitments without implying guarantees that cannot be evidenced.

Retain capacity trends, monitoring results, recovery objectives, backup evidence, restore tests, continuity exercises, incident records, service-level evidence, dependency risks, and corrective actions. Reassess design after major architecture, vendor, workload, or commitment changes.

Chapter 08 — Processing-integrity implementation model

Where processing integrity is relevant, define controls that support authorized, complete, accurate, timely, and valid processing consistent with the system's commitments. Address input validation, processing logic, interfaces, error handling, reconciliation, job monitoring, data transformations, output controls, and controlled changes.

Evidence should demonstrate the defined processing population, exception detection, reconciliation, correction, authorization, monitoring, and change history. Do not claim processing integrity solely from application availability or generic security controls.

Chapter 09 — Confidentiality implementation model

Identify information designated confidential by commitments, contracts, policy, or business need and map how it is classified, accessed, transmitted, stored, shared, retained, and disposed of. Apply controls proportionate to sensitivity and contractual requirements.

Maintain data inventories, classification rules, access records, encryption/key-management evidence where applicable, transfer controls, retention schedules, disposal evidence, vendor responsibilities, and exception records. Keep confidentiality distinct from privacy even when the same information is both confidential and personal.

Chapter 10 — Privacy implementation model

Where privacy is in scope, define how personal information is governed across collection, notice, choice or consent where applicable, use, access, disclosure, retention, correction, deletion, security, quality, and monitoring. Map privacy commitments and system requirements to operational controls without treating SOC 2 as a substitute for legal compliance analysis.

Maintain data inventories, notices, request-handling records, retention/deletion evidence, sharing records, processor/subprocessor governance, incident procedures, training, complaints, and monitoring results. Legal interpretations remain with qualified legal/privacy professionals.

Chapter 11 — Risk assessment and control design

Operate a documented risk process that considers objectives, commitments, threats, vulnerabilities, fraud, technology change, third parties, privacy, availability, software supply chain, identity, operational dependencies, and prior incidents. Define risk criteria, owners, treatment decisions, approval thresholds, and reassessment triggers.

Connect each material risk to controls or an explicit treatment decision. Evidence should show risk identification, analysis, control design rationale, acceptance or remediation, ownership, due dates, review history, and linkage to changes in the system.

Chapter 12 — Governance and policy management

Create a governance structure that makes control ownership visible and policies operational. Each controlled policy or standard should have an owner, approver, version, effective date, review date, distribution/training requirement, exception process, and mapped operating controls.

Use recurring management review to address overdue evidence, exceptions, incidents, control failures, scope changes, vendor issues, and remediation aging. Policy approval alone is not operating evidence; retain proof that required activities actually occurred.

Chapter 13 — Logical access and identity lifecycle

Govern workforce, contractor, third-party, privileged, service, application, and machine identities from request through removal. Define role design, least privilege, joiner/mover/leaver processes, approvals, provisioning, periodic review, inactive-account handling, and evidence retention.

Maintain complete populations from authoritative identity systems where possible. Evidence should link requests, approvals, provisioning, changes, reviews, removals, and exceptions to specific identities and time periods. Reassess access controls after organizational, platform, or authentication changes.

Chapter 14 — Privileged access and MFA

Treat privileged access as a distinct risk domain. Inventory administrative roles and accounts, restrict assignment, use strong authentication, control emergency access, protect credentials/secrets, log privileged activity where appropriate, and review entitlement and use.

Evidence should include privileged-account populations, approvals, MFA configuration, access reviews, vault or secrets-management records where applicable, emergency-access records, monitoring results, and timely revocation. Shared or unmanaged privileged access requires explicit remediation or risk treatment.

Chapter 15 — System operations and monitoring

Define operating procedures for production services, security tooling, jobs, interfaces, capacity, alerts, incidents, maintenance, and routine review. Identify required monitoring coverage, owners, thresholds, escalation paths, evidence retention, and failure handling.

Retain operational dashboards or exports, alert/case records, job results, maintenance evidence, issue tickets, escalation records, and management metrics. Monitoring should demonstrate response to meaningful conditions, not merely that a tool is enabled.

Chapter 16 — Vulnerability and configuration management

Maintain inventories and approved configuration expectations for in-scope components. Operate vulnerability discovery, evaluation, prioritization, remediation, exception, retest, and metric processes appropriate to the environment.

Evidence should link findings to affected assets, owners, risk decisions, due dates, fixes, retests, and exceptions. Configuration evidence should show baseline approval, implementation status, change history, drift handling, and periodic verification. Scanner output alone is not proof of effective remediation.

Chapter 17 — Incident response and recovery

Maintain an incident-response program with defined severity, roles, escalation, investigation, containment, evidence preservation, communications, recovery, lessons learned, and corrective action. Integrate cyber, privacy, availability, vendor, and operational events where relevant to the system.

Test the plan through exercises and retain scenarios, participants, results, gaps, actions, and closure evidence. Material incidents should trigger reassessment of risks, controls, system-description accuracy, commitments, vendor dependencies, and examination disclosures.

Chapter 18 — Change management and secure development lifecycle

Require traceable authorization, risk/impact analysis, testing, review, deployment approval, rollback planning, and post-change verification for material changes. Integrate security requirements, vulnerability remediation, dependency management, code review, CI/CD controls, production-access boundaries, and emergency-change handling as appropriate.

Evidence may include tickets, pull requests, approvals, test results, deployment logs, release records, emergency reviews, and segregation-of-duties controls. Preserve the full change population needed for Type 2 sampling and reconcile it to source systems.

Chapter 19 — Logging, alerting, and evidence retention

Define which systems and control activities require logs, alerts, audit trails, and retained evidence. Set collection, time synchronization, access, retention, review, escalation, and integrity expectations based on system risk and engagement needs.

Maintain source inventories, retention settings, representative logs, alert cases, review evidence, access records, and exception handling. Evidence repositories should protect confidential information and preserve provenance, while allowing authorized auditor access through controlled channels.

Chapter 20 — Backup, resilience, and availability monitoring

Define backup scope, frequency, protection, retention, restoration testing, resilience mechanisms, dependencies, and operational monitoring. Align recovery design with documented service commitments and business impact rather than relying on generic targets.

Retain backup job populations, failure handling, restore-test evidence, resilience/failover exercises, capacity and uptime monitoring, recovery actions, and remediation. A successful backup job does not demonstrate recoverability unless restoration is periodically validated.

Chapter 21 — Vendor and subservice-organization governance

Inventory third parties and subservice organizations that host, process, support, secure, or materially affect the in-scope system. Define due diligence, risk tiering, contracting, responsibility mapping, assurance review, monitoring, incident escalation, change management, and termination controls.

Retain contracts/security terms, due-diligence records, assurance reports, bridge letters or equivalent updates where relevant, findings, complementary subservice-organization considerations, service changes, incidents, and remediation. Reassess dependencies when architecture or services change.

Chapter 22 — Complementary user-entity controls

Identify controls or responsibilities that user entities are expected to perform for the service organization's controls and commitments to operate as intended. Tie each complementary user-entity control to the relevant service boundary, communication mechanism, and assumption.

Management should ensure these responsibilities are accurately described and communicated and should avoid using them to shift responsibility for controls the service organization actually owns. Maintain evidence of identification, review, customer communication, and system-description reconciliation.

Chapter 23 — Cloud and shared-responsibility considerations

Map cloud services, managed platforms, SaaS dependencies, inherited controls, customer-configured controls, identities, logging, key management, network boundaries, data locations, and vendor responsibilities. Document where responsibility is shared and where the service organization must produce its own evidence.

Use provider assurance reports as evidence inputs, not as automatic proof that the organization's configuration or responsibilities are effective. Retain service inventories, responsibility matrices, configuration evidence, provider assurance reviews, exceptions, and change triggers.

Chapter 24 — Privacy operations and data lifecycle

Operationalize personal-data governance through inventories, purpose/commitment mapping, access controls, retention schedules, deletion, sharing, request handling, incident processes, vendor controls, and monitoring. Reconcile privacy operations with the actual system and customer commitments.

Evidence should be population-based where possible and should show timeliness, approvals, outcomes, exceptions, and corrective action. Keep legal-compliance conclusions separate from SOC 2 readiness evidence and route jurisdiction-specific interpretation to qualified professionals.

Chapter 25 — Evidence population and sampling readiness

For recurring controls, preserve complete and reproducible populations from authoritative sources. Define how populations are generated,

reconciled, protected, and tied to the examination period. Avoid hand-curated lists that exclude failures or lack provenance.

Each evidence object should identify source system, query/report method, owner, period, population size, selection context, retained artifact, reviewer, and exceptions. Sampling decisions belong to the practitioner; management's responsibility is to provide complete, accurate evidence and explain how it was produced.

Chapter 26 — Type 1 versus Type 2 readiness

A Type 1 readiness model focuses on whether controls are suitably designed and implemented as of a specified date. A Type 2 readiness model must also support evidence of control operation over the relevant period. Confirm intended report type with the independent practitioner and customer/business requirements.

For Type 2, build evidence calendars before the period begins, preserve recurring populations, monitor missed activities, and remediate early. Do not backfill or recreate evidence in a way that misrepresents when or how a control operated.

Chapter 27 — Exception, deviation, and remediation governance

Define how control exceptions, evidence gaps, deviations, incidents, and test findings are recorded, assessed, owned, remediated, retested, and escalated. Distinguish isolated documentation gaps from control-design or operating failures based on evidence rather than convenience.

Maintain issue identifiers, affected controls/populations, impact, root cause where practical, owner, due date, interim treatment, remediation evidence, retest result, recurrence analysis, and management decisions. Do not delete failed population items to improve apparent performance.

Chapter 28 — Management review and continuous monitoring

Operate management review throughout the year using control-health indicators, evidence completion, exception aging, incidents, vendor changes, access-review results, vulnerability trends, recovery testing, policy reviews, and system changes. Define escalation thresholds and decision rights.

Retain meeting records or equivalent approvals, dashboards, exceptions, decisions, risk acceptances, remediation commitments, and follow-up

evidence. Continuous monitoring supports readiness but does not replace practitioner testing or judgment.

Chapter 29 — Auditor interaction and request management

Select an appropriately qualified independent CPA firm and establish controlled communication, evidence-transfer, request tracking, milestones, scope discussions, issue escalation, and confidentiality handling. Management should provide accurate information and disclose known relevant issues rather than optimizing submissions solely for appearance.

Maintain a request log with owner, due date, artifact, status, questions, follow-up, and resolution. Readiness personnel may organize evidence and explain processes but must not direct or constrain the practitioner's independent procedures or conclusions.

Chapter 30 — Report reading, qualifications, and findings

Prepare management and authorized report users to read the final report in context: service/system scope, criteria/categories, period or date, subservice treatment, complementary user-entity controls, tests, exceptions, management responses, and any qualifications or limitations. Avoid reducing the report to a binary badge.

Track report findings and exceptions to remediation and reassessment. External statements about SOC 2 status should be accurate, current, consistent with contractual restrictions and report use, and should never imply a certification or broader assurance than the report provides.

Chapter 31 — Continuous compliance and change triggers

Maintain readiness between examinations through recurring control operation, evidence collection, risk review, vendor monitoring, access governance, vulnerability/configuration management, recovery tests, policy review, and issue remediation. Define triggers that require scope, control, system-description, or evidence-process reassessment.

Examples include acquisitions, new products, major cloud migrations, authentication redesign, new processors, significant incidents, material outages, new commitments, architecture changes, and control automation.

Record impact decisions and ensure affected evidence procedures change with the system.

Chapter 32 — Release, reassessment, and evidence lifecycle

Before treating the controlled manual as publication-ready, verify the authoritative AICPA source state, complete the exact English master, derive controlled es-419 and pt-BR drafts from that exact source, run structural/copyright/terminology/parity QA, generate exact DOCX/PDF candidates, run rendered accessibility/visual/content QA, stage durable binaries, record SHA-256 provenance, reconcile lifecycle metadata, and confirm predecessor publication.

For organizational use, define evidence retention, confidentiality, secure transfer, versioning, supersession, and reassessment rules. Do not publish confidential customer evidence, employee data, secrets, production screenshots, or actual restricted audit workpapers in public examples. Material changes reopen affected gates rather than silently carrying forward stale evidence.

Authoritative references

- AICPA & CIMA SOC 2 topic and resource surface.
- AICPA & CIMA 2017 Trust Services Criteria (With Revised Points of Focus — 2022), used only as authoritative criteria reference and not reproduced here.
- AICPA & CIMA 2018 SOC 2 Description Criteria (With Revised Implementation Guidance — 2022), used only as authoritative description reference and not reproduced here.
- AICPA & CIMA SOC for Service Organizations Engagements — Overview, refreshed April 23, 2026.

Release-time source verification remains mandatory because authoritative standards and guidance may change.